

Security Assessment Report

Acme Financial Services Ltd

Engagement Type	Security Assessment & C2 Detection Audit
Assessment Period	2026-05-26 — 2026-06-01
Report Date	June 01, 2026
Assessor	Tinlance Limited — FDSE Team
Classification	CONFIDENTIAL
Version	1.0

OVERALL RISK: HIGH | Score: 7.4/10

CRITICAL	HIGH	MEDIUM	LOW	INFO
3	2	4	2	1

01 — Executive Summary

Tinlance conducted a forward-deployed security assessment of Acme Financial Services' network infrastructure and endpoint environment between May 26 and June 1, 2026. The assessment identified 3 critical, 5 high, 4 medium, and 2 low severity findings. The most significant finding is active C2 beacon traffic consistent with Cobalt Strike patterns detected on 3 internal hosts, indicating a likely active intrusion that requires immediate containment. Immediate remediation of critical findings is strongly recommended.

Business Impact

If unaddressed, the active C2 activity exposes Acme to data exfiltration, ransomware deployment, and regulatory fines under NIS2 (up to €10 million or 2% of global turnover). The 72-hour NIS2 incident reporting clock may already be running. Immediate containment and notification should be prioritised.

Key Recommendations

- Isolate the 3 affected hosts immediately and initiate incident response
- Engage CSIRT within 24 hours per NIS2 Article 23 requirements
- Deploy ThreatFade endpoint agent across all 847 endpoints within 48 hours
- Patch critical CVEs on internet-facing systems within 7 days
- Implement network segmentation to limit lateral movement

02 — Scope & Methodology

In Scope

- External perimeter — 14 internet-facing IP addresses
- Internal network — /16 subnet (847 active hosts)
- 3 web applications (customer portal, admin panel, API gateway)
- Active Directory environment — 1 forest, 2 domains
- Endpoint fleet — Windows 10/11 (712 hosts), Linux (135 hosts)

Out of Scope

- OT/SCADA systems (separate engagement planned)
- Physical security controls
- Third-party SaaS applications

Methodology

PTES (Penetration Testing Execution Standard) + MITRE ATT&CK; framework. ThreatFade entropy/z-score analysis for network traffic. BugFlow Elite v6 for automated reconnaissance and vulnerability discovery.

Tools Used

ThreatFade v0.2.0-beta · BugFlow Elite v6 · ReconOS OSINT Engine · FusionOps v0.3.0 · Nmap · Burp Suite Pro

03 — Technical Findings

TF-001	Active C2 Beacon Traffic — Cobalt Strike Pattern Detected	CRITICAL	CVSS 9.8
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H		
Affected Systems	192.168.10.45 192.168.10.67 192.168.11.203		
MITRE ATT&CK;	T1071.001 — Application Layer Protocol: Web Protocols T1573 — Encrypted Channel T1095 — Non-Application Layer Protocol		
Description	ThreatFade detected statistically anomalous outbound traffic from 3 internal hosts with z-score 7.01, consistent with Cobalt Strike HTTP/S beacon patterns. Traffic analysis reveals periodic callbacks at 60-second intervals to an external IP (203.0.113.47) with encrypted payload signatures matching known Cobalt Strike malleable C2 profiles.		
Evidence	ThreatFade detection log: z-score=7.01, entropy=0.87, drop_ratio=0.23. Packet capture confirmed 60-second beacon interval. MITRE TTP mapping: T1071.001, T1573.		
Business Impact	Active adversary presence. Risk of lateral movement, credential harvesting, data exfiltration, and ransomware deployment. NIS2 incident reporting obligation likely triggered.		
Remediation	1. Immediately isolate affected hosts (192.168.10.45, .67, 192.168.11.203). 2. Block outbound traffic to 203.0.113.47 at perimeter firewall. 3. Engage incident response team. 4. Submit NIS2 early warning notification to CSIRT within 24 hours. 5. Deploy ThreatFade endpoint agent across full fleet to identify additional compromised hosts.		
Effort	Immediate (0-24 hours)		

TF-002	SQL Injection — Customer Portal Login Form	CRITICAL	CVSS 9.1
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H		
Affected Systems	portal.acme-example.com — /login endpoint		
MITRE ATT&CK;	T1190 — Exploit Public-Facing Application		
Description	Unauthenticated SQL injection vulnerability in the customer portal login form allows extraction of the entire customer database including names, email addresses, hashed passwords, and account balances.		
Evidence	BugFlow confirmed via sqlmap — UNION-based injection on 'username' parameter. Successfully extracted 3 rows from 'customers' table in proof-of-concept (non-destructive test only).		
Business Impact	Full customer database exposure. GDPR Article 33 breach notification obligation. Reputational damage. Regulatory fines.		
Remediation	1. Apply parameterised queries / prepared statements immediately. 2. Deploy WAF rule blocking SQL metacharacters on login endpoint. 3. Rotate all customer credentials. 4. Notify DPA within 72 hours per GDPR Article 33.		
Effort	Short-term (1-7 days)		

TF-003	IcedID Loader Pattern — Suspicious Download Activity		CRITICAL	CVSS 9.0
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H			
Affected Systems	192.168.12.88			
MITRE ATT&CK;	T1566.001 — Phishing: Spearphishing Attachment T1059.001 — PowerShell			
Description	ThreatFade detected traffic with z-score 3.89 consistent with IcedID loader download patterns on host 192.168.12.88. The host performed 14 DNS lookups to domains matching IcedID DGA patterns within a 10-minute window.			
Evidence	ThreatFade detection: z-score=3.89, entropy=2.1. DNS logs confirm 14 DGA-pattern lookups. Host has not been reimaged in 847 days.			
Business Impact	Potential banking trojan deployment risk. IcedID is commonly used as a precursor to ransomware. Possible credential theft from financial applications.			
Remediation	1. Isolate host 192.168.12.88 immediately. 2. Reimage from known-good baseline. 3. Review email logs for phishing delivery vector. 4. Block identified DGA domains at DNS level.			
Effort	Immediate (0-24 hours)			

BF-001	Outdated Apache HTTP Server — CVE-2024-38476		HIGH	CVSS 8.1
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H			
Affected Systems	api.acme-example.com (Apache/2.4.51)			
MITRE ATT&CK;	T1190 — Exploit Public-Facing Application			
Description	The API gateway runs Apache HTTP Server 2.4.51 which is vulnerable to CVE-2024-38476, a server-side request forgery and information disclosure vulnerability.			
Evidence	BugFlow Nuclei scan confirmed version 2.4.51. CVE-2024-38476 PoC available publicly.			
Business Impact	Potential access to internal services from external network. Information disclosure of internal network topology.			
Remediation	Upgrade Apache HTTP Server to 2.4.62 or later.			
Effort	Short-term (1-7 days)			

BF-002	Weak Password Policy — Active Directory		HIGH	CVSS 7.5
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N			
Affected Systems	Active Directory — ACME.LOCAL domain			
MITRE ATT&CK;	T1110.001 — Brute Force: Password Guessing			
Description	Active Directory password policy allows minimum 6-character passwords with no complexity requirements. 23% of sampled accounts (47 of 204) used passwords from the RockYou2024 wordlist.			
Evidence	BugFlow AD audit identified policy: MinPasswordLength=6, ComplexityEnabled=False. Hashcat cracked 47 NTLM hashes from DC sync in under 4 hours using RockYou2024.			

Business Impact	Credential compromise enables lateral movement, privilege escalation, and domain takeover.
Remediation	1. Enforce minimum 12-character passwords with complexity. 2. Enable MFA for all accounts — mandatory per NIS2 Article 21(2)(j). 3. Force password reset for all 47 compromised accounts. 4. Deploy Azure AD Password Protection or equivalent.
Effort	Short-term (1-7 days)

RO-001	Exposed Internal Hostnames in Public DNS Records	MEDIUM	CVSS 5.3
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N		
Affected Systems	DNS — public zone acme-example.com		
MITRE ATT&CK;	T1590.002 — Gather Victim Network Information: DNS		
Description	ReconOS OSINT scan identified 14 internal hostnames exposed in public DNS records, including dev.acme-example.com (pointing to 10.0.0.x internal IP) and staging-api.acme-example.com.		
Evidence	ReconOS AfricanContextEngine DNS enumeration: 14 internal PTR records exposed. Zone transfer partially successful from ns2.acme-example.com.		
Business Impact	Reconnaissance enablement. Exposes internal architecture to threat actors prior to attack.		
Remediation	1. Remove internal hostnames from public DNS zone. 2. Disable zone transfers on public nameservers. 3. Audit all DNS records for internal exposure.		
Effort	Medium-term (1-4 weeks)		

TF-004	Missing Network Segmentation — Flat Network Architecture	MEDIUM	CVSS 6.5
CVSS Vector	CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N		
Affected Systems	Network infrastructure — full /16 subnet		
MITRE ATT&CK;	T1021 — Remote Services T1018 — Remote System Discovery		
Description	The internal network operates as a single flat /16 subnet with no VLAN segmentation between workstations, servers, and critical systems. ThreatFade detected lateral movement traffic patterns across the network.		
Evidence	Network traffic analysis: workstation-to-workstation SMB traffic observed. No ACLs between workstation and server subnets. ThreatFade lateral movement alert triggered 7 times during assessment.		
Business Impact	Any compromised endpoint has unrestricted access to all other systems. Enables rapid ransomware spread.		
Remediation	1. Implement VLAN segmentation (workstations, servers, DMZ, management). 2. Deploy micro-segmentation for critical assets. 3. Implement network ACLs between zones.		
Effort	Medium-term (1-4 weeks)		

BF-003	Unencrypted Internal API Traffic (HTTP)	MEDIUM	CVSS 5.9
--------	---	--------	----------

CVSS Vector	CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Affected Systems	Internal API service — 192.168.20.10:8080
MITRE ATT&CK;	T1040 — Network Sniffing
Description	Internal microservice API communicates over HTTP (unencrypted) on port 8080, transmitting session tokens and customer data in cleartext.
Evidence	BugFlow network capture on flat network segment. Captured 3 valid session tokens and 2 customer records in cleartext during 10-minute passive capture.
Business Impact	Session hijacking and customer data exposure risk. DORA ICT risk management gap.
Remediation	Enforce TLS 1.2+ on all internal API communications. Implement mutual TLS for service-to-service authentication.
Effort	Medium-term (1-4 weeks)

RO-002	Third-Party SaaS Credentials in Public GitHub Repository	MEDIUM	CVSS 6.8
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N		
Affected Systems	github.com/acme-corp — dev repository (public)		
MITRE ATT&CK;	T1552.001 — Unsecured Credentials: Credentials in Files		
Description	ReconOS OSINT scan identified a public GitHub repository containing hardcoded Paystack test API keys and an AWS access key ID in a committed .env file.		
Evidence	ReconOS Nigerian fintech detector (inherited from Tinlance open-source contributions) flagged Paystack key pattern. AWS key validated as active via sts:GetCallerIdentity.		
Business Impact	Paystack account compromise. AWS resource abuse and potential data access.		
Remediation	1. Immediately revoke and rotate exposed credentials. 2. Make repository private or remove sensitive files. 3. Implement git-secrets or TruffleHog pre-commit hooks. 4. Audit all repositories for credential exposure.		
Effort	Immediate (0-24 hours)		

BF-004	Missing Security Headers on Customer Portal	LOW	CVSS 3.7
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N		
Affected Systems	portal.acme-example.com		
MITRE ATT&CK;	T1185 — Browser Session Hijacking		
Description	Customer portal missing: Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy headers.		
Evidence	BugFlow HTTP header scan confirmed absence of 5 security headers. Clickjacking PoC confirmed with X-Frame-Options missing.		
Business Impact	Clickjacking, MIME-type sniffing, and information leakage risks.		

Remediation	Add security headers to web server configuration. Use SecurityHeaders.com to validate.
Effort	Short-term (1-7 days)

BF-005	Default SNMP Community String on Network Devices	LOW	CVSS 2.7
CVSS Vector	CVSS:3.1/AV:A/AC:L/PR:H/UI:N/S:U/C:L/I:N/A:N		
Affected Systems	192.168.1.1 — Core switch 192.168.1.2 — Distribution switch		
MITRE ATT&CK;	T1602 — Data from Configuration Repository		
Description	Network switches using default SNMP community string 'public', enabling read access to network topology and device configuration.		
Evidence	BugFlow SNMP scan confirmed community string 'public' on 2 core switches. Successfully retrieved interface table and routing table.		
Business Impact	Network topology disclosure enabling more targeted attacks.		
Remediation	Change SNMP community strings to complex unique values. Implement SNMPv3 with authentication.		
Effort	Short-term (1-7 days)		

RO-003	Informal Patch Management Process	INFO	CVSS 0.0
CVSS Vector	N/A		
Affected Systems	Organisational process — IT Operations		
MITRE ATT&CK;	T1190 — Exploit Public-Facing Application (risk factor)		
Description	No formal patch management policy or tooling identified. 23 systems show OS versions more than 6 months behind current release.		
Evidence	BugFlow asset inventory: 23 hosts with end-of-support or critically outdated OS versions. No WSUS or SCCM deployment confirmed.		
Business Impact	Increased attack surface from unpatched vulnerabilities over time. NIS2 risk management requirement gap.		
Remediation	Implement formal patch management policy with defined SLAs. Deploy automated patching tool (WSUS, Intune, or equivalent).		
Effort	Medium-term (1-4 weeks)		

04 — ThreatFade Live Detections

The following threats were detected live by ThreatFade v0.2.0-beta during the assessment engagement. All detections are based on entropy analysis and z-score statistical modelling validated against known malware traffic signatures.

Timestamp	Host	Threat	Z-Score	Severity	MITRE TTP
2026-05-27 09:14:22	192.168.10.45	Cobalt Strike C2 Beacon	7.01	CRITICAL	T1071.001
2026-05-27 09:14:23	192.168.10.67	Cobalt Strike C2 Beacon	6.87	CRITICAL	T1071.001
2026-05-27 11:30:05	192.168.12.88	IcedID Loader Pattern	3.89	CRITICAL	T1566.001
2026-05-28 14:22:11	192.168.11.203	Cobalt Strike C2 Beacon	7.14	CRITICAL	T1573
2026-05-29 08:45:00	192.168.10.45	Lateral Movement SMB	4.21	HIGH	T1021

05 — NIS2 Compliance Gap Assessment

Acme Financial Services has significant NIS2 compliance gaps. 6 of 10 assessed controls are non-compliant. The October 2026 compliance deadline is approaching. Immediate remediation of critical gaps is required to avoid fines of up to €10 million.

NIS2 Control	Reference	Status	Gap Details
Risk management policies	Article 21(2)(a)	PARTIAL	Policy exists but not formally documented or board-approved
Incident handling procedures	Article 21(2)(b)	GAP	No formal IR plan. Active incident (TF-001) has no documented response proc
Business continuity & recovery	Article 21(2)(c)	PARTIAL	BCP exists for operational systems but not tested in 18 months
Supply chain security	Article 21(2)(d)	GAP	No vendor security assessment programme. RO-002 credentials from third-par
Network & information system security	Article 21(2)(e)	GAP	Flat network, no segmentation, active C2 beacon undetected prior to assessm
Policies on cryptography	Article 21(2)(h)	PARTIAL	HTTPS on external systems. Internal API traffic unencrypted (TF-003)
Human resources security	Article 21(2)(i)	PARTIAL	Basic onboarding but no security awareness programme
Multi-factor authentication	Article 21(2)(j)	GAP	MFA not enforced on AD or VPN. Mandatory under NIS2
Incident reporting (24hr/72hr)	Article 23	GAP	TF-001 C2 incident may already require 24hr CSIRT notification
Management accountability	Article 20	GAP	No designated CISO or security accountability at board level

06 — Remediation Roadmap

The following prioritised roadmap translates all findings into a time-phased action plan. Phase 1 addresses active threats requiring immediate containment. Subsequent phases address systemic security gaps.

Phase 1 — Immediate (0-24 hrs)

- Isolate TF-001 hosts
- Block C2 IP at perimeter
- Notify CSIRT (NIS2)
- Revoke exposed credentials (RO-002)
- Begin IR process

Phase 2 — Short-term (1-7 days)

- Patch SQLi (TF-002)
- Upgrade Apache (BF-001)
- Force AD password reset
- Add security headers (BF-004)
- Change SNMP strings (BF-005)

Phase 3 — Medium-term (1-4 wks)

- Implement network segmentation
- Enforce internal TLS (BF-003)
- Clean up DNS (RO-001)
- Deploy MFA on AD + VPN
- Implement patch management

Phase 4 — Long-term (1-3 months)

- Deploy ThreatFade across full fleet
- Establish NIS2 compliance programme
- Board-level CISO appointment
- Security awareness training
- Vendor security assessment programme

This report was prepared by Tinlance Limited for Acme Financial Services Ltd. It is classified CONFIDENTIAL and intended solely for the named client. Unauthorised distribution is prohibited.

Tinlance Limited · RC: 7962164 · tinlance.com · ThreatFade v0.2.0-beta · June 01, 2026